

Наименование источника угрозы (Source)	Индекс
Конкуренты	S ₁
Недобросовестные партнеры	S ₂
Персонал организации	S ₃
Хакеры, мошенники	S ₄

Наименование угрозы (Security threat)	Индекс
Инсталляция и запуск вирусов	ST ₁
Несанкционированный доступ	ST ₂
DDOS-атаки	ST ₃
Перехват трафика	ST ₄
Проникновение во внутреннюю сеть	ST ₅
Внешнее сканирование	ST ₆
Проникновение через сервисы	ST ₇
Спам, подмена сообщений/отправителя	ST ₈

6

Реализовано напрямую

Концепт	В реализации	Где смотреть
S1..S4 источники	threat_sources: 4 записи	migrations/007_threat_sources.up.sql
ST угрозы	threats: демо-угрозы + угрозы ФСТЭК	migrations/002_seed_data.up.sql, 005_bdufstec_threats.up.sql
Индекс угрозы	threats.bdu_id, threats.q_threat, threats.q_severity	migrations/010_threat_q_fields.up.sql

Как показать на листе

Справа от исходной таблицы поставь компактную таблицу “Концепт → БД/API”. Для доказательства можно добавить кусок результата SQL:

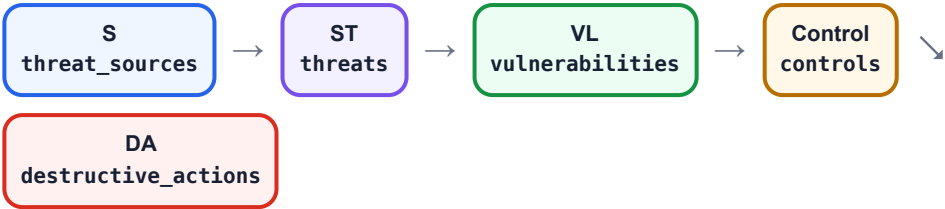
- S1 Конкуренты
- S2 Недобросовестные партнёры
- S3 Персонал
- S4 Хакеры, мошенники

Что важно честно написать

В PDF перечислены 8 базовых угроз ST1..ST8. В системе они не ограничены восьмёркой: есть демо-угрозы, угрозы ФСТЭК и поля для БДУ. SQLite-снэпшот БДУ лежит в data/bdu.sqlite: 86 664 уязвимости, 715 615 записей ПО, 114 483 CVE.

2. Цепочка ST → VL → методы → DA

Реальная структура графа



Связи хранятся в source_threats, threat_vulnerable_links, vulnerability_controls, threat_destructive_actions.

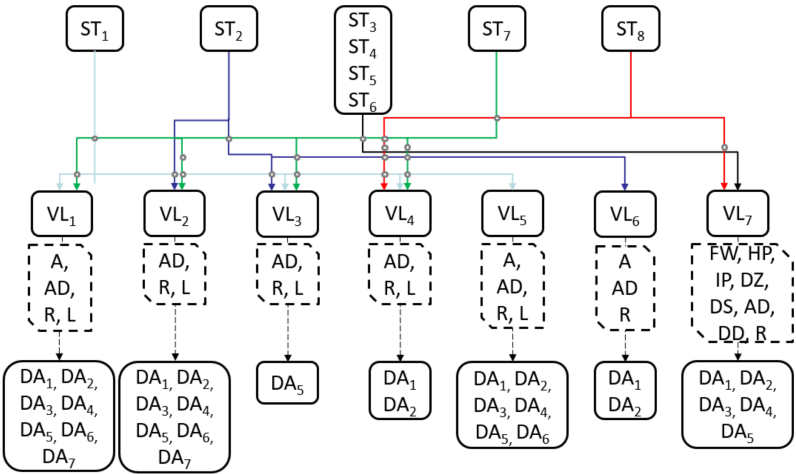
Пример из живого API

GET /api/risk/graph/1/1 для “Web Application Server” и “SQL Injection Attack” возвращает:

Блок	Пример
Источники	S1 “Конкуренты”, S4 “Хакеры, мошенники”
VL	Unpatched Web Framework, Insufficient Input Validation
Controls	Regular Patch Management, Web Application Firewall
DA	DA1 “Копирование”, DA4 “Модификация”

Что вставить как картинку

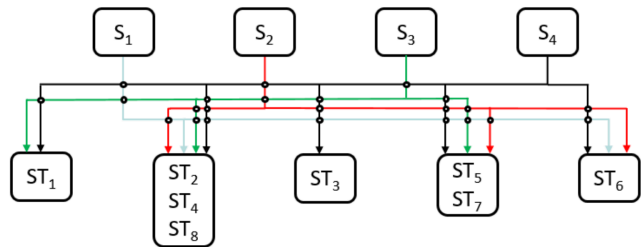
Лучше всего: скрин страницы <http://localhost:3000/risk/graph/1>. Если скрин не нужен, оставь эту схему справа: она точнее отражает таблицы и API, чем исходный линейный рисунок.



ST_i – Наименование угрозы VL_i – Наименование уязвимого звена DA_i – Наименование
destructive действия – Методы противодействия – Перекрещенные линии

3. Связи S → ST

PDF: источники применяют угрозы → Реализация: таблица связей



- S_i – Наименование источника угрозы
- ST_i – Наименование угрозы
- – Перекрещенные линии

7

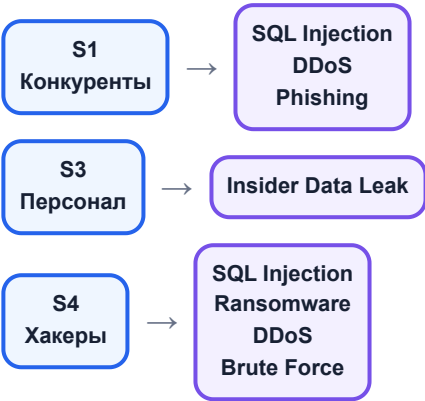
Как это сделано

В коде нет “нарисованных линий”. Линии из PDF стали строками в junction-таблице:

source_threats(threat_source_id, threat_id)

Первичный seed: migrations/010_threat_q_fields.up.sql. Дополнение для демо-графа: migrations/011_seed_risk_graph_links.up.sql.

Схема для вставки



Как подписать

“Перекрещенные линии концепта в реализации нормализованы в таблицу связей. Это позволяет хранить любое число источников и угроз, а не фиксированную картинку.”

Наименование уязвимого звена (Vulnerable link)	Индекс
Нештатное дополнительное ПО (драйверы, утилиты)	VL ₁
Наличие устаревших версий ПО или версий имеющие уязвимости	VL ₂
Допустимость установки не декларируемого ПО	VL ₃
Наличие процедуры обхода администратором установленных правил и режимов безопасности в сети	VL ₄
Носители информации (флеш-накопители, жесткие диски)	VL ₅
Открытые ОС	VL ₆
Отсутствие средств защиты ЛВС	VL ₈
Метод противодействия	Индекс
Антивирус	A
Межсетевой экран	FW
Honey port	HP
Демилитаризованная зона ЛВС	DZ
Системы обнаружения вторжений	IDS
Системы (настройки) администрирования	AD
Резервное копирование	R
Программная защита информации от НСД	L
Шифрование трафика	TE
Цифровая подпись	DS
DDOS фильтры	DD
Наименование деструктивного действия (Destructive action)	Индекс
Копирование (чтение) информации	DA ₁
Перехват информации	DA ₂
Уничтожение информации	DA ₃
Модификация информации	DA ₄
Блокирование информации	DA ₅
хищение информации	DA ₆

Сопоставление справочников

Концепт	В реализации	Комментарий
VL1..VL7	vulnerabilities, asset_vulnerabilities	В демо-базе 5 VL, в SQLite БДУ 86 664 уязвимости.
A, FW, HP, DZ, IDS, AD, R, L, TE, DS, DD	controls, asset_controls, vulnerability_controls	Хранятся как именованные меры, не только аббревиатуры.
DA1..DA7	destructive_actions	7 действий заведены ровно по концепции.

DA реализованы один в один

DA1 копирование

DA2 перехват

DA3 уничтожение

DA4 модификация

DA5 блокирование

DA6 хищение

DA7 нарушение работоспособности

Что лучше не скрывать

Аббревиатуры методов из PDF не перенесены в интерфейс как отдельные коды. В реализации они представлены через реальные controls: WAF, patch management, database access control, network segmentation, backup, IDS, training.

Главный объект реализации

Поле	Что содержит
sources	S1..S4 для угрозы
vulnerable_links	VL + controls + признак uncovered
destructive_actions	DA1..DA7, связанные с угрозой
w, q_threat, q_severity, q_reaction, z	расчет по формуле ПТСЗИ

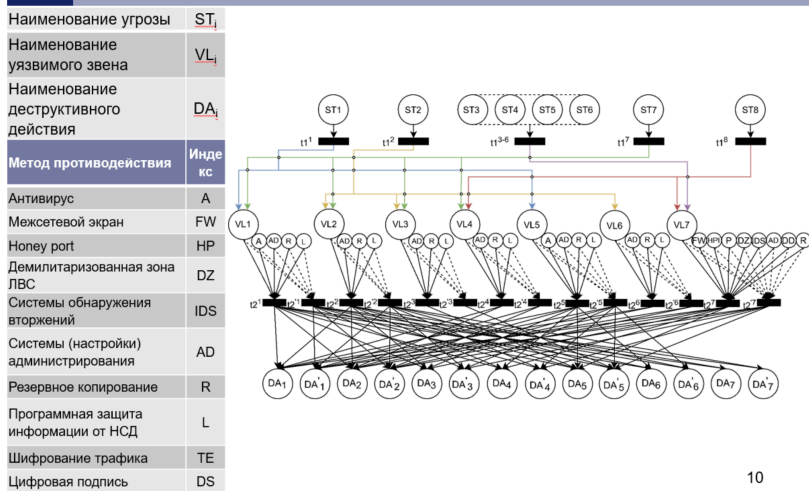
API: GET /api/risk/graph/:asset_id/:threat_id.

UI: <http://localhost:3000/risk/graph/1>.

Для листа диплома лучше вставить не весь JSON, а скрин UI или схему с колонками S → ST → VL → Control → DA.

```
graph LR; Asset[Asset] -- "+" --> Threat[Threat]; Threat -- "→" --> LoadAttackPath[LoadAttackPath]; LoadAttackPath -- "→" --> Q_reaction[Q reaction]; Q_reaction -- "→" --> W_level[W + level];
```

Файлы: `risk_graph_repository.go`, `service.go`, `calculator_v2.go`, `RiskGraphPage.tsx`.



6. Формула W

$$W_i = \frac{Q_i theat + q_i theat + (1 - Q_i reaction)}{3} \cdot Z; \in [0,1]$$

где $Q_{i}theat$ – степень реализации угрозы $\in [0,1]$;

$Q_{i\text{reaction}}$ – степень предотвращения угрозы $\in [0,1]$;

$q_i theat$ – степень опасности угрозы $\in [0,1]$;

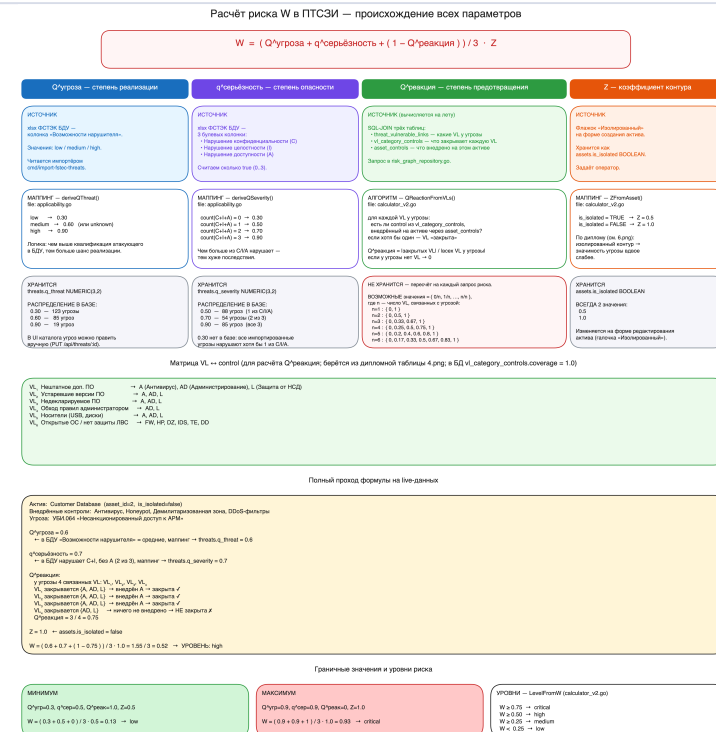
Z – коэффициент критичности угрозы для контура (необходимо для ослабления значимости угрозы. Е случае, когда угроза актуальна для обоих контуров примем $Z = 1$, в противном случае $Z = 0,5$.

Формула реалізована

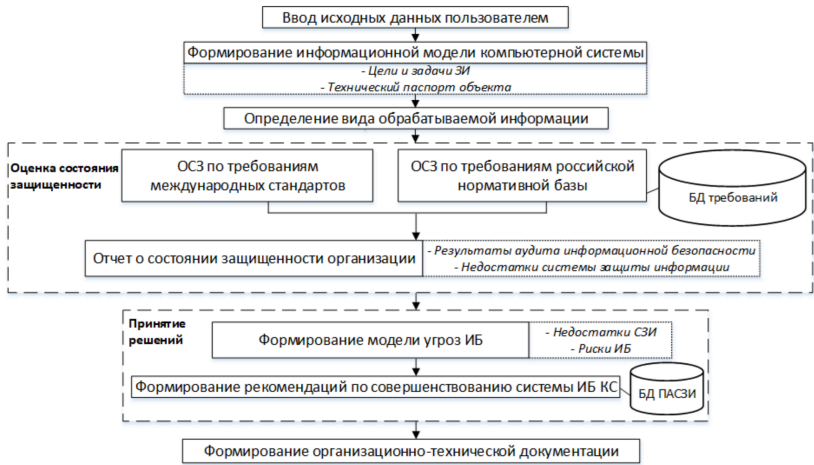
$$W = (Q_{\text{threat}} + q_{\text{severity}} + (1 - Q_{\text{reaction}})) / 3 * Z$$

Параметр	Откуда берется	Файл
Q_threat	threats.q_threat	calculator_v2.go
q_severity	threats.q_severity	calculator_v2.go
Q_reaction	доля VL, закрытых внедренными controls	risk_graph_repository.go
Z	asset.environment и asset.is_isolated	calculator_v2.go

Готовая картинка

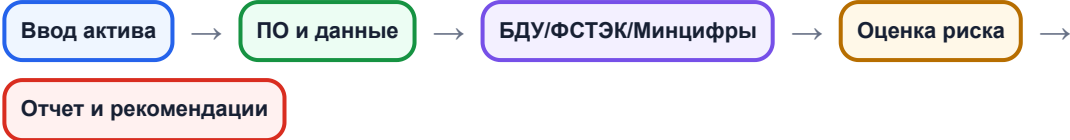


Структурно-функциональная схема автоматизированной системы

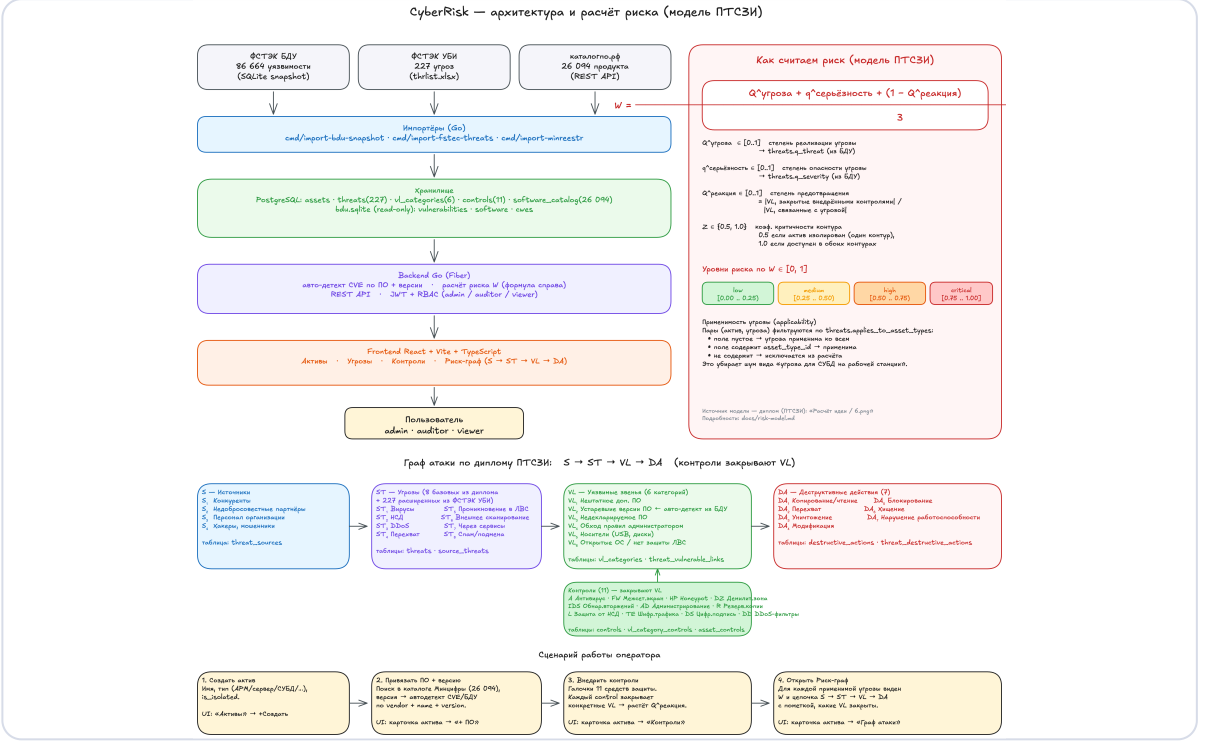


14

Как заменить концептуальную схему



Готовая картинка архитектуры



Подпись к листу

“БД требований” из концепции разнесена на PostgreSQL для рабочей модели и SQLite-снэпшот БДУ ФСТЭК для внешних справочников. Отчетность и рекомендации реализованы как сервисные слои и UI-страницы.”

Результаты работы программного комплекса



Что показать скринами

ИТ-активы организации

Управление и мониторинг критически важных активов

5 Всего активов | 3 Критичных | 4 В процессе | 3,8 Средняя критичность

Web Application Server	PROD	Критичный	5	1	4	0	0	0	0
Customer Database	PROD	Критичный	5	5	4	0	0	0	0
Employee Workstation Network	PROD	Важный	3	3	4	0	0	0	0
Development Server	DEV	Средний	2	2	3	0	0	0	0

Реестр активов: исходные данные пользователя

Справочник программного обеспечения

Корпоративный каталог ПО с информацией о сертификации и включении в реестр

50 Всего ПО | 49 В реестре РФ | 34 Сертифицировано ФСТЭК | 2 Сертифицировано ФСБ

ПО	Провайдер	Категория	Сертификация
1С:Предприятие 8	1С	---	PE
Angular	Web-Сервер	---	PE
Alpha Linux Special Edition	РубAltex-Алтра	---	PE, FSTEC
Avastor FAM v5	ООО «Авастор»	---	PE, FSTEC
ClickHouse	Яндекс	---	PE
CommonJS Pro	СтандартJS	---	PE
Delia Lock	Конфидент	---	PE, FSTEC
Deckhouse v100	ООО «Велит»	---	PE
Py Mail Enterprise Gateway Suite	Роском Вел	---	PE, FSTEC

Справочник ПО: Минцифры/каталог ПО

Карта рисков

Матрица распределения сценариев риска (Возможность × Вероятность)

155 Всего сценариев | 78 Критичный | 41 Высокий | 31 Средний | 5 Низкий

Возможность (Y)	1	2	3	4	5
5	Зеленый	Желтый	Оранжевый	Красный	Красный
4	Зеленый	Желтый	Оранжевый	Красный	Красный
3	Зеленый	Желтый	Оранжевый	Красный	Красный
2	Зеленый	Желтый	Оранжевый	Красный	Красный
1	Зеленый	Желтый	Оранжевый	Красный	Красный

Карта рисков: результат оценки

Симулятор риска

Инструмент быстрого моделирования "Что если?" для оценки потенциального риска

Параметры расчета: ИТ-актив: Web Application Server, Оценка: PROD, Критичность: 5/5

Угроза: Угроза несанкционированного доступа к конфиденциальной информации

Выборите актив и угрозу для расчета

Симулятор риска: расчет сценария

Как связать с PDF

PDF-блок	Экран/модуль
Модель угроз ИБ	/risk/graph/:assetId, /risk/map
Мероприятия защиты	controls, рекомендации, симулятор
Орг.-тех. документация	PDF-отчет по сценарию риска
Рекомендации	recommendations.go, recommendation_templates